

IPsec e IKEv2 Pós-Quânticos: Protegendo VPNs Corporativas com RFC 9370, RFC 9242 e ML-KEM

Day 07 | Category: Segurança de Redes Privadas Virtuais (VPNs) e Corporativa

Date: 2026-07-14 | DAILY

MONITORING

Introdução: A Ameaça Quântica às VPNs Corporativas

As redes privadas virtuais corporativas (VPNs) dependem fortemente do protocolo **IPsec (Internet Protocol Security)** e do seu plano de controle, o **IKEv2 (Internet Key Exchange Protocol Version 2)**, para estabelecer túneis criptográficos seguros em redes não confiáveis. Tradicionalmente, os pares usam o clássico Diffie-Hellman (DH) ou Elliptic Curve Diffie-Hellman (ECDH) durante a fase `IKE_SA_INIT` para concordar com as chaves de sessão. No entanto, a criptografia de chave pública clássica é altamente vulnerável a futuros computadores quânticos que executam o algoritmo de Shor, expondo o tráfego corporativo a ataques do tipo "Harvest-Now, Decrypt-Later" (HNDL).

Harvest-Now, Decrypt-Later (HNDL): Adversários passivos gravam hoje o tráfego criptografado de handshake e dados das VPNs. Assim que um computador quântico criptograficamente relevante (CRQC) estiver disponível, eles poderão decifrar as sessões históricas, expondo dados corporativos confidenciais, credenciais e propriedade intelectual proprietária.

RFC 9370: Viabilizando Múltiplas Trocas de Chaves no IKEv2

Em maio de 2023, o IETF publicou a **RFC 9370**, que estende o IKEv2 para permitir a realização de múltiplas trocas de chaves durante o estabelecimento de uma Associação de Segurança (SA). Em vez de forçar uma transição abrupta dos algoritmos clássicos para os pós-quânticos — o que introduziria riscos significativos de migração —, a RFC 9370 padroniza uma abordagem híbrida. Isso garante que as chaves derivadas permaneçam criptograficamente seguras desde que *por pelo menos um* dos algoritmos (clássico ou pós-quântico) permaneça íntegro.

Para implementar isso, a RFC 9370 aproveita a troca **IKE_INTERMEDIATE** (definida na **RFC 9242**). Veja como a estrutura do handshake é adaptada:

- **IKE_SA_INIT:** O iniciador e o respondente realizam uma troca de chaves clássica e leve (por exemplo, usando X25519 ou ECDH Curve P-256) para estabelecer um canal criptografado

inicial. Essa etapa leve evita que ataques de negação de serviço (DoS) esgotem recursos intensivos de computação pós-quântica.

- **IKE_INTERMEDIATE:** Dentro do canal recém-criptografado — porém vulnerável quânticamente —, os pares realizam uma ou mais trocas intermediárias para transmitir as cargas úteis de Mecanismos de Encapsulamento de Chaves (KEM) pós-quânticos de maior tamanho (como o ML-KEM-768).
- **IKE_AUTH:** Por fim, os pares autenticam-se mutuamente, compilam todos os resultados das trocas e derivam as chaves de sessão seguras (KEYSEED), combinando os segredos compartilhados clássicos e pós-quânticos.

O Papel Vital da Troca IKE_INTERMEDIATE (RFC 9242)

Os algoritmos pós-quânticos, especificamente os KEMs baseados em reticulados como o ML-KEM, exigem chaves públicas e textos cifrados substancialmente maiores do que seus equivalentes clássicos. Por exemplo, uma chave pública ML-KEM-768 possui 1.184 bytes, em comparação com apenas 32 bytes do X25519. Se essas cargas úteis fossem comprimidas no pacote inicial `IKE_SA_INIT`, a mensagem facilmente excederia a Unidade Máxima de Transmissão (MTU) padrão da Ethernet de 1.500 bytes. Isso levaria à fragmentação de IP na camada de rede, que é frequentemente bloqueada por firewalls e roteadores intermediários, resultando em falhas de conexão.

Ao utilizar o `IKE_INTERMEDIATE`, a troca de chaves pós-quântica é realizada após a ativação do canal criptografado inicial, permitindo que o protocolo gerencie pacotes maiores com segurança e utilize os recursos integrados de fragmentação criptográfica do IKEv2 se necessário.

Aplicabilidade no Mundo Real da Cibersegurança e Status em 2026

A transição das VPNs IPsec corporativas para a segurança pós-quântica está deixando de ser um rascunho teórico para se tornar uma implantação ativa e generalizada em produção. Em 2026, vários líderes do setor já integraram essas capacidades:

- **Rascunhos de Padrões IETF:** O rascunho `draft-ietf-ipsecme-ikev2-mlkem` especifica o mapeamento direto do ML-KEM (FIPS 203) como a troca de chaves adicional sob a RFC 9370, eliminando problemas anteriores de interoperabilidade causados por suítes de cifra não padronizadas.
- **Cloudflare One:** A Cloudflare atualizou sua plataforma SASE (Secure Access Service Edge) para suportar ML-KEM híbrido para túneis IPsec, permitindo que clientes corporativos protejam seus escritórios, VPCs e filiais contra ataques HNDL.
- **Fortinet (FortiOS 7.6.1):** Os firewalls de próxima geração (NGFW) da Fortinet agora oferecem suporte a ML-KEM-512, ML-KEM-768 e ML-KEM-1024 em conformidade com o FIPS 203, permitindo trocas híbridas robustas e de múltiplas rodadas.

- **StrongSwan:** O daemon IPsec de código aberto amplamente utilizado recebeu integrações experimentais de sucesso do ML-KEM em conjunto com aceleração de hardware para gateways corporativos de alto desempenho.

Comparação de Métricas Chave: Clássico vs. Híbrido vs. PQC Puro

A tabela abaixo resume as compensações em tamanhos de parâmetros, rodadas de comunicação e resiliência criptográfica entre diferentes perfis de troca de chaves no IKEv2.

Método de Troca de Chaves	Criptografia Base	Tamanho da Chave Pública	Tamanho do Texto Cifrado	Resistência Quântica	Risco de Fragmentação
X25519 (Clássico)	ECDH (Curve25519)	32 bytes	32 bytes	Nenhuma (Vulnerável ao CRQC)	Insignificante
ML-KEM-768 (PQC Puro)	Reticulados / Module-Lattice (FIPS 203)	1.184 bytes	1.088 bytes	Sim (NIST Nível 3)	Moderado (se no IKE_SA_INIT)
Híbrido X25519 + ML-KEM-768 (RFC 9370)	Híbrido (DH + Reticulados)	1.216 bytes	1.120 bytes	Sim (Clássico + PQ Failsafe)	Baixo (Mitigado via IKE_INTERMEDIATE)

Daily Quiz / Auto-Avaliação

1. Por que a RFC 9370 não recomenda o envio das chaves públicas do ML-KEM diretamente na carga útil do `IKE_SA_INIT` ?

- a) Porque o ML-KEM não é seguro o suficiente para ser enviado em texto limpo.
- b) Porque o grande tamanho das chaves e textos cifrados do ML-KEM provocaria fragmentação de IP, que é frequentemente bloqueada por firewalls e intermediários de rede.
- c) Porque violaria a especificação FIPS 203.

Resposta: b) O grande tamanho das chaves baseadas em reticulados excede os limites de MTU típicos, e realizar a troca no `IKE_INTERMEDIATE` evita falhas por fragmentação.

2. Qual é a principal vantagem de segurança de uma troca de chaves híbrida (ex: X25519 + ML-KEM-768) sobre uma troca de chaves puramente pós-quântica?

- a) Ela é executada duas vezes mais rápido que o PQC puro.
- b) Ela atende aos requisitos legais de padrões clássicos e mantém a segurança caso a hipótese clássica OU a hipótese pós-quântica permaneça válida.
- c) Ela usa chaves menores do que o ECDH padrão.

Resposta: b) Oferece uma margem dupla de segurança, atuando como um plano de contingência (failsafe) criptográfico contra potenciais falhas matemáticas ou de implementação nos novos algoritmos PQC padronizados.

3. De que forma a RFC 9370 atualiza a terminologia estabelecida na RFC 7296 para o IKEv2?

- a) Substitui o IPsec por PQ-IPsec.
- b) Renomeia o Tipo de Transformação 4 de "Grupo Diffie-Hellman (D-H)" para "Método de Troca de Chaves (KE)" para generalizar todos os tipos de mecanismos de troca de chaves, incluindo os KEMs pós-quânticos.
- c) Deprecia o ESP (Encapsulating Security Payload).

Resposta: b) Generaliza o tipo de transformação e os campos para acomodar facilmente mecanismos que não são do tipo DH clássico, como o encapsulamento de chaves pós-quânticas.